CS 645

Security and Privacy in Computer Systems

Lecture 3: Physical security

- Authentication based on physical tokens
- Locks and safes
- Authentication based on biometrics
- Direct attacks against computers

Administrative issues

- Please make sure you read the "Announcements" section

- Posted first and second set of review questions

Last Week

- Authentication systems
- Text passwords
- Attacks against password-based authentication
  - Dictionary attacks
  - Pre-computed dictionary attacks
  - Rainbow tables
- Improving the security of text passwords
  - Password salting
  - One-time passwords
- Real-world attacks on password files
- Graphical passwords
  - Windows picture password

Authentication based on physical tokens

Physical Security

- The use of physical measures to protect valuables, information, or access to restricted resources
  - Location protection
  - Physical intrusion detection
  - Hardware attacks
  - Eavesdropping
  - Physical interface attacks

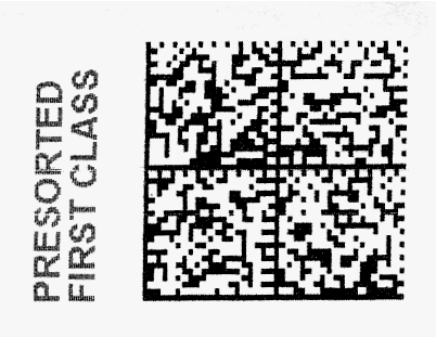
Authentication technologies

- Something you know
- Something you have
- Something you are

Barcodes

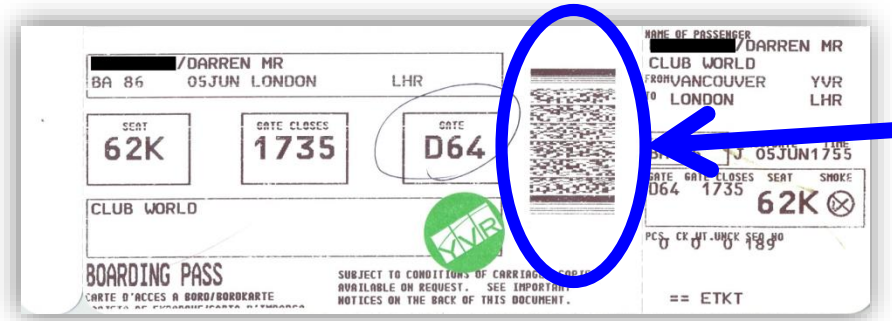
- Developed in the 20th century to improve efficiency in grocery checkout.
- First-generation barcodes represent data as a series of **variable-width, vertical lines** of ink, which is essentially a one-dimensional encoding scheme.

- Some more recent barcodes are rendered as **two-dimensional patterns** using dots, squares, or other symbols that can be read by specialized optical scanners, which translate a specific type of barcode into its encoded information.



Authentication via Barcodes

- Since 2005, the airline industry has been incorporating two-dimensional barcodes into boarding passes, which are created at flight check-in and scanned before boarding.
- In most cases, the barcode is encoded with an internal unique identifier that allows airport security to look up the corresponding passenger's record with that airline.
- Staff then verifies that the boarding pass was in fact purchased in that person's name (using the airline's database), and that the person can provide photo identification.
- In most other applications, however, barcodes provide convenience but not security. Since barcodes are simply images, they are extremely easy to duplicate.



Two-dimensional barcode

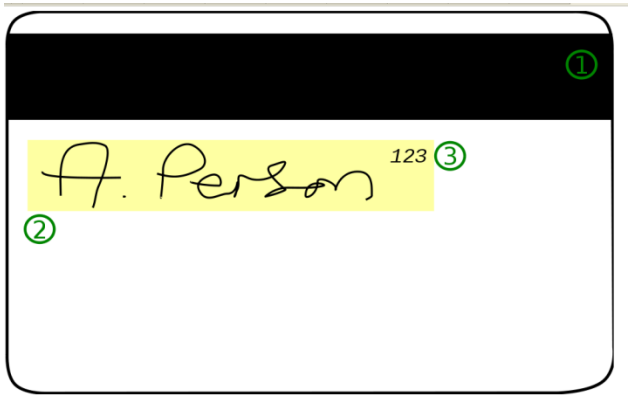
Public domain image from http://commons.wikimedia.org/wiki/File:Bpass.jpg

Boarding Pass Generator

- In 2006, a doctoral student (Chris Soghoian) created a website with a NWA fake boarding pass generator
  - http://www.dubfire.net/boarding_pass/
  - He received a visit from the FBI, computers were confiscated, but both TSA and FBI investigations were later dropped.
  - He even wrote a paper analyzing the security of boarding passes and other airport security flaws in depth: “Insecure Flight: Broken Boarding Passes and Ineffective Terrorist Watch Lists”.

Magnetic Stripe Cards

- Plastic card with a magnetic stripe containing personalized information about the card holder.
- The first track of a magnetic stripe card contains the cardholder's full name in addition to an account number, format information, and other data.
- The second track may contain the account number, expiration date, information about the issuing bank, data specifying the exact format of the track, and other discretionary data.



Public domain image by *Alexander Jones* from http://commons.wikimedia.org/wiki/File:CCardBack.svg

Magnetic Stripe Card Security

- One vulnerability of the magnetic stripe medium is that it is easy to read and reproduce.
- Magnetic stripe readers can be purchased at relatively low cost, allowing attackers to read information off cards.
- When coupled with a magnetic stripe writer, which is only a little more expensive, an attacker can easily clone existing cards.
  - Skimming attacks (swipe card and record details; must also get the Card Security Code, which is not present on the magnetic strip)
- So, many uses require card holders to enter a PIN to use their cards (e.g., as in ATM and debit cards in the U.S.).
- Some systems store monetary value directly on the card
  - Not a good idea (MIFARE Classic card used for transportation system in Boston was broken in 2009)

Smart Cards

- **Smart cards** incorporate an integrated circuit, optionally with an on-board microprocessor, which features reading and writing capabilities, allowing the data on the card to be both accessed and altered.
- Smart card technology can provide secure authentication mechanisms that protect the information of the owner and are extremely difficult to duplicate.
- By design, they are difficult to physically disassemble

Circuit interface

Public domain image from http://en.wikipedia.org/wiki/File:Carte_vitale_anonyme.jpg

Smart Card Authentication

- They are commonly employed by large companies and organizations as a means of strong authentication using cryptography.

- Smart cards may also be used as a sort of “electronic wallet,” containing funds that can be used for a variety of services, including parking fees, public transport, and other small retail transactions.

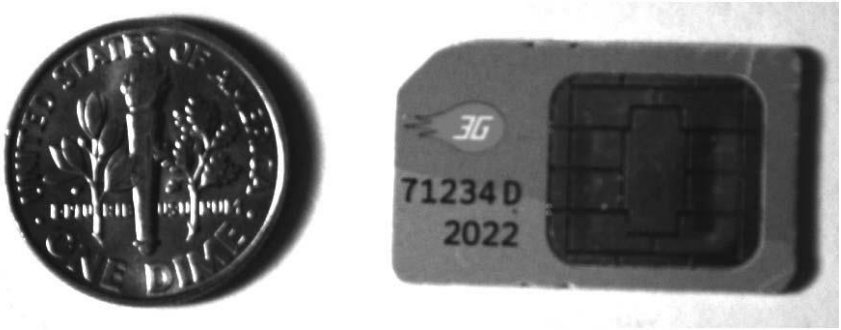
Smart Card Security

- More sophisticated cards feature a microprocessor that allows them to perform some computational work and alter card contents
- Other simpler cards only contain memory (an external writer is needed) (e.g., many phone cards are like this, and contain a monetary amount)

- Most cards require that a secret authentication code be presented to a microcontroller reader/writer before memory can be written on the card.
  - In addition, many phone cards authenticate themselves to the phone network using a PIN mechanism before any transfer of funds takes place
- Differential power analysis attack

SIM Cards

- Many mobile phones use a special smart card called a **subscriber identity module card (SIM card).**
- A SIM card is issued by a network provider. It maintains personal and contact information for a user and allows the user to authenticate to the cellular network of the provider.

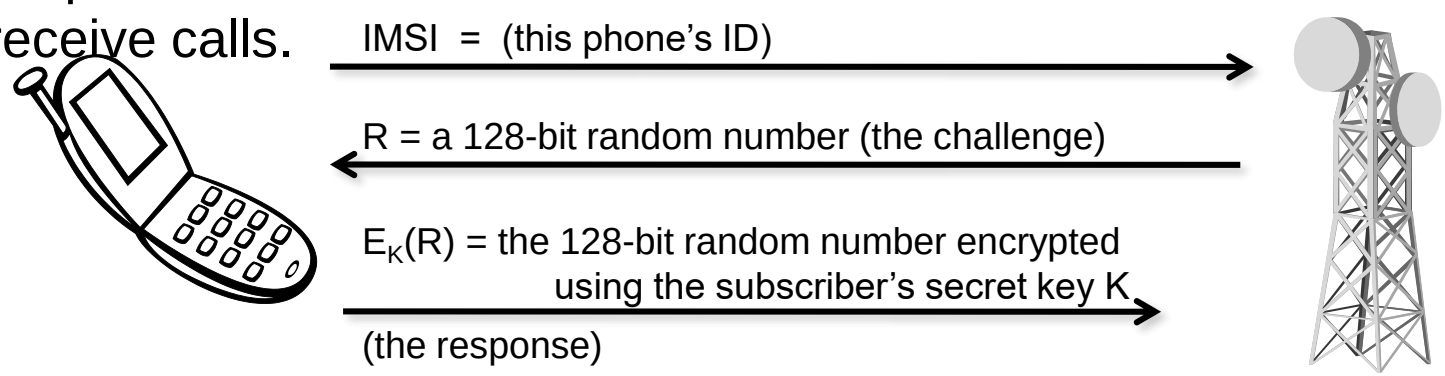


SIM Card Security

- SIM cards contain several pieces of information that are used to identify the owner and authenticate to the appropriate cell network.
- Each SIM card corresponds to a record in the database of subscribers maintained by the network provider.
- A SIM card features an **integrated circuit card ID (ICCID),** which is a unique 18-digit number used for hardware identification.
- Next, a SIM card contains a unique **international mobile subscriber identity** (**IMSI),** which identifies the owner's country, network, and personal identity.
- SIM cards also contain a 128-bit **secret key.** This key is used for authenticating a phone to a mobile network.
- As an additional security mechanism, many SIM cards require a PIN before allowing any access to information on the card.

GSM Challenge-Response Protocol

1. When a cellphone wishes to join a cellular network it connects to a local **base station** owned by the network provider and transmits its IMSI.
2. If the IMSI matches a subscriber's record in the network provider's database, the base station transmits a 128-bit random number to the cellphone.
3. This random number is then encrypted by the cellphone with the subscriber's secret key stored in the SIM card using a proprietary encryption algorithm known as **A3,** resulting in a ciphertext that is sent back to the base station**.**
4. The base station then performs the same computation, using its stored value for the subscriber's secret key. If the two ciphertexts match, the cellphone is authenticated to the network and is allowed to make and receive calls.



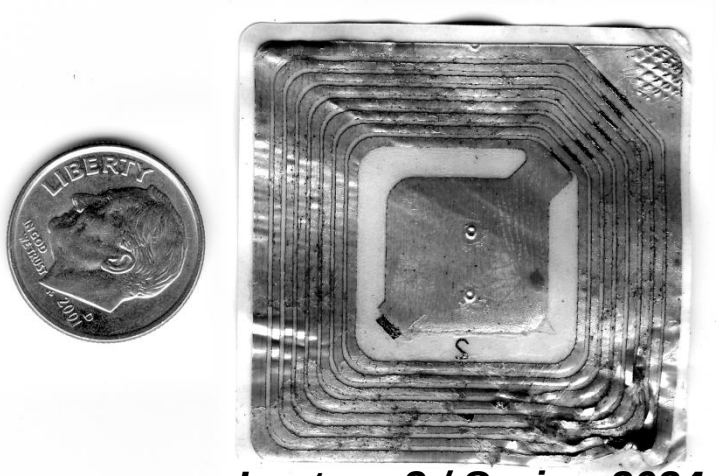
SIM Card Security

- September 2019: Simjacker
- SIM card attack method that could work against over 1 billion mobile phones
- The attack involves sending a specially crafted SMS message to the targeted phone
- The message contains SIM Toolkit (STK) instructions and it's processed by the SIM card (the universal integrated circuit card, or UICC), specifically the S@T Browser present on the SIM.
- Attacker can send commands for playing a tone, sending SMS messages, making phone calls, collecting information about the device (location, IMEI, battery, language), launching a web browser, powering off the card, requesting geographical location, and exfiltrating data.

https://blog.knowbe4.com/holy-simoly-simjacker-sim-card-attack-used-to-spy-on-mobile-phone-users

RFIDs

- **Radio frequency identification, or RFID,** is a rapidly emerging technology that relies on small transponders to transmit identification information via radio waves.
- RFID chips feature an integrated circuit for storing information, and a coiled antenna to transmit and receive a radio signal.



RFID Technology

- RFID tags must be used in conjunction with a separate reader or writer.
- While some RFID tags require a battery, many are passive and do not.
- The effective range of RFID varies from a few centimeters to several meters, but in most cases, since data is transmitted via radio waves, it is not necessary for a tag to be in the line of sight of the reader.

RFID Technology

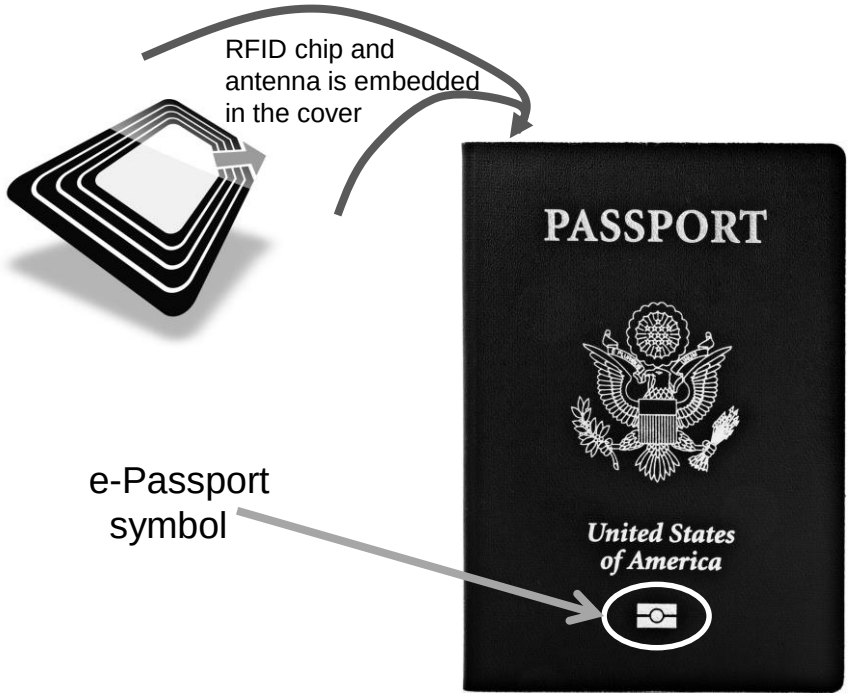
- This technology is being deployed in a wide variety of applications.
- Many vendors are incorporating RFID for product tracking (automatic tracking in the supply chain, track which items sell best, theft detection, etc.).
- Car key fobs.
- Electronic toll transponders (EZPass).

RFID Applications

- Digital Signature Transponder
  - Digital Signature Transponder (DST) – automobile key fob for automatic payment at gas stations (Exxon-Mobil Speedpass), and also used in vehicle immobilizer systems
  - Stores 40-bit secret key and uses proprietary encryption algorithm DST40
  - DST40 was reversed engineered and weaknesses in DST40 allowed attacks that allow to extract the secret key
- Electronic Toll Systems
  - Provide great convenience, but no encryption mechanism protects the contents of the RFID tag
  - Tags can be cloned

Passports

- Modern passports of several countries, including the United States, feature an embedded RFID chip
- The chip contains information about the owner, including a digital facial photograph that allows airport officials to compare the passport's owner to the person who is carrying the passport.



Passport Security

- In order to protect the sensitive information on a passport, all RFID communications are encrypted with a **secret key.**
- In many instances, however, this secret key is merely the passport number, the holder's date of birth, and the expiration date, in that order.
  - All of this information is printed on the card, either in text or using a barcode or other optical storage method.
  - While this secret key is intended to be only accessible to those with physical access to the passport, an attacker with information on the owner, including when their passport was issued, may be able to easily reconstruct this key, especially since passport numbers are typically issued sequentially.

Locks and safes

Physical Security - again

- Any physical object that creates a barrier to unauthorized access
- This includes: locks, latches, safes, alarms, guards, guard dogs, doors, windows, walls, ceilings, floors, fences, door strikes, door frames and door closers

Is Physical Security An IT Concern?

- You have been working hard to secure your network from cyber attacks
  - Redundant layers of antivirus programs, firewalls and intrusion detection systems should protect against every possible electronic method of entry
- But what if an attacker gains access to the server room or network wiring closet …
- Is your network still safe?

Compromising Locks

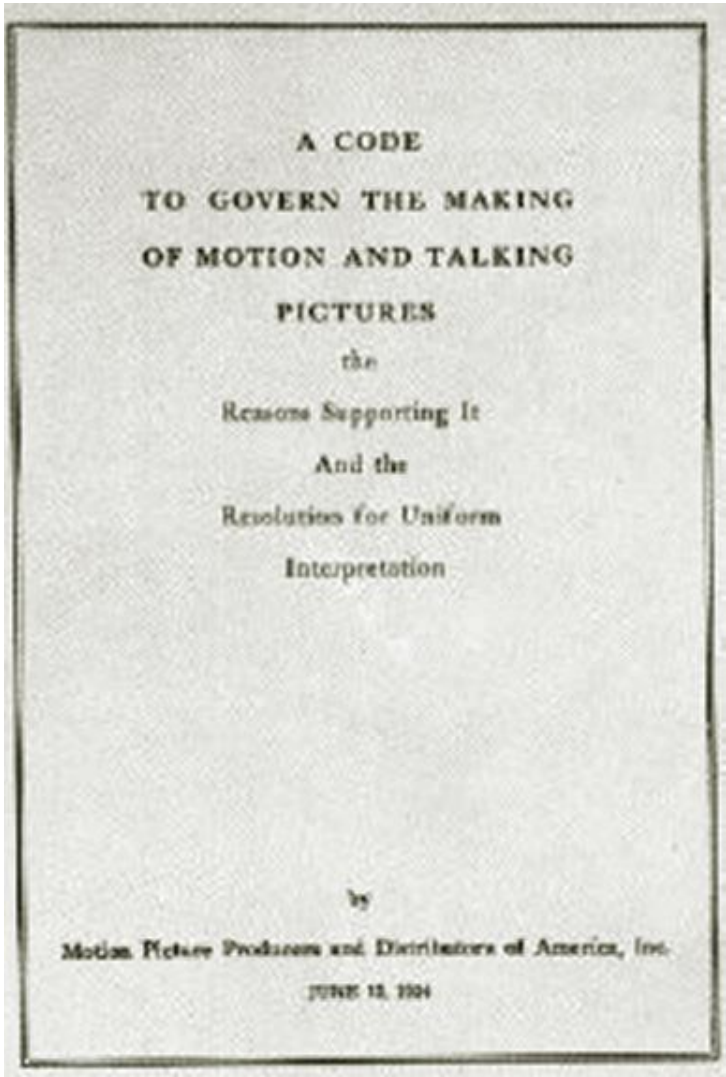
- For centuries, the lock has been one of the cornerstones of physical security
  - We rely on dozens of them every day to protect people and assets
- The trust most people place in locks is unwarranted
  - Most locks can be easily compromised with nondestructive methods
  - Sometimes within seconds and with readily available tools
- “Locks keep honest people honest”

Lock Picking

- Lock picking had been the exclusive art of locksmiths, professional thieves, spies and magicians for hundreds of years
- However, with the advent of the Internet, information about lock picking methods and tools has become readily available
  - E.g., YouTube has many lock picking videos

Lock Picking in Movies

- Genuine lock picking in movies used to be prohibited
- Before 1967, the Hays code (Motion Picture Production Code) required censorship of Hollywood movies
  - "All detailed (that is, imitable) depiction of crime must be removed, such as lock picking or mixing of chemicals to make explosives"


A CODE

TO GOVERN THE MAKING

OF MOTION AND TALKING

PICTURES

the

Reasons Supporting It

And the

Resolutions for Uniform

Interpretation

by

Motion Picture Producers and Distributors of America, Inc.

JUNE 13, 1934

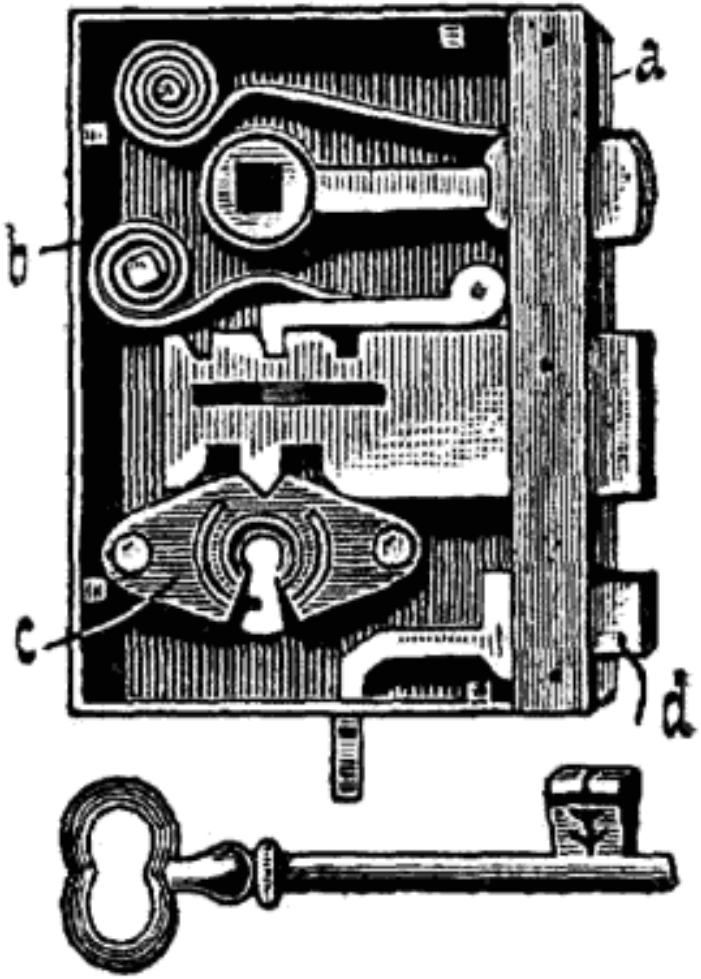
Public domain image from http://commons.wikimedia.org/wiki/File:Motion_Picture_Production_Code.gif

LOCK TYPES

Image from http://commons.wikimedia.org/wiki/File:Ancient_warded_lock_open.jpg used with permission under Gnu Free Documentation License 1.2

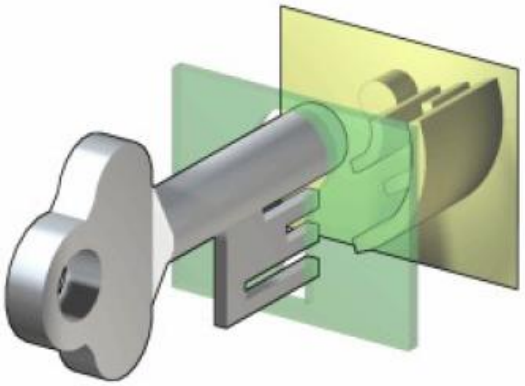
Warded Locks

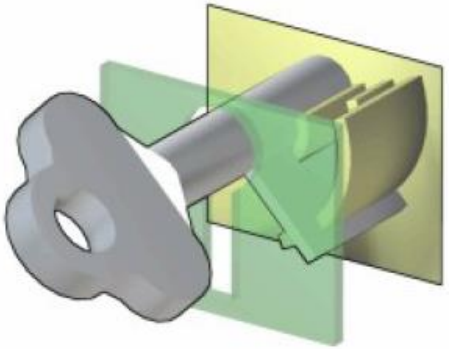
- Locks of this type were used in ancient times
- The key moves the bolt assisted by a support spring
- Security relies on the fact that not all keys pass through the key hole



Skeleton Key for warded locks

- Usually in old style doors or desks
- Different concentric obstructions
- Easy to lock pick with Skeleton keys
- They come from ancient Rome

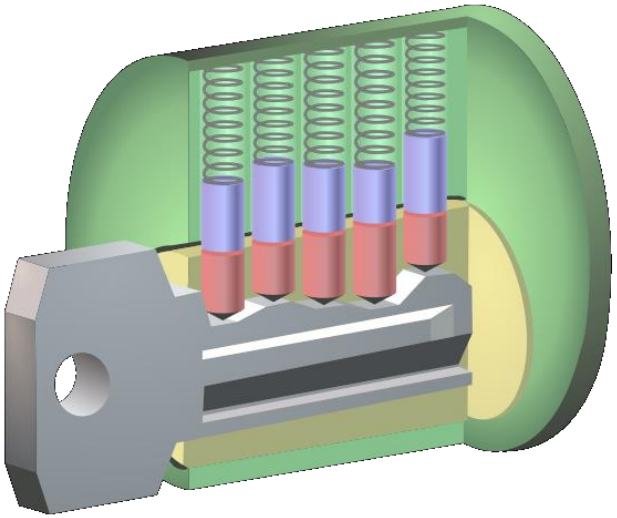




Images from http://en.wikipedia.org/wiki/File:Warded_locked.png used by permission under Gnu free documentation license 1.2

1860: Yale Pin Tumbler Lock

- Modern version of the Egyptian single-pin design
- Utilizes two pins for locking (pin stack)



- A cylindrical plug is housed within an outer casing
  - Shear line = the area where the plug meets the outer casing
- Lock is opened when the plug rotates and releases a locking bolt, typically through a lever

Terminology

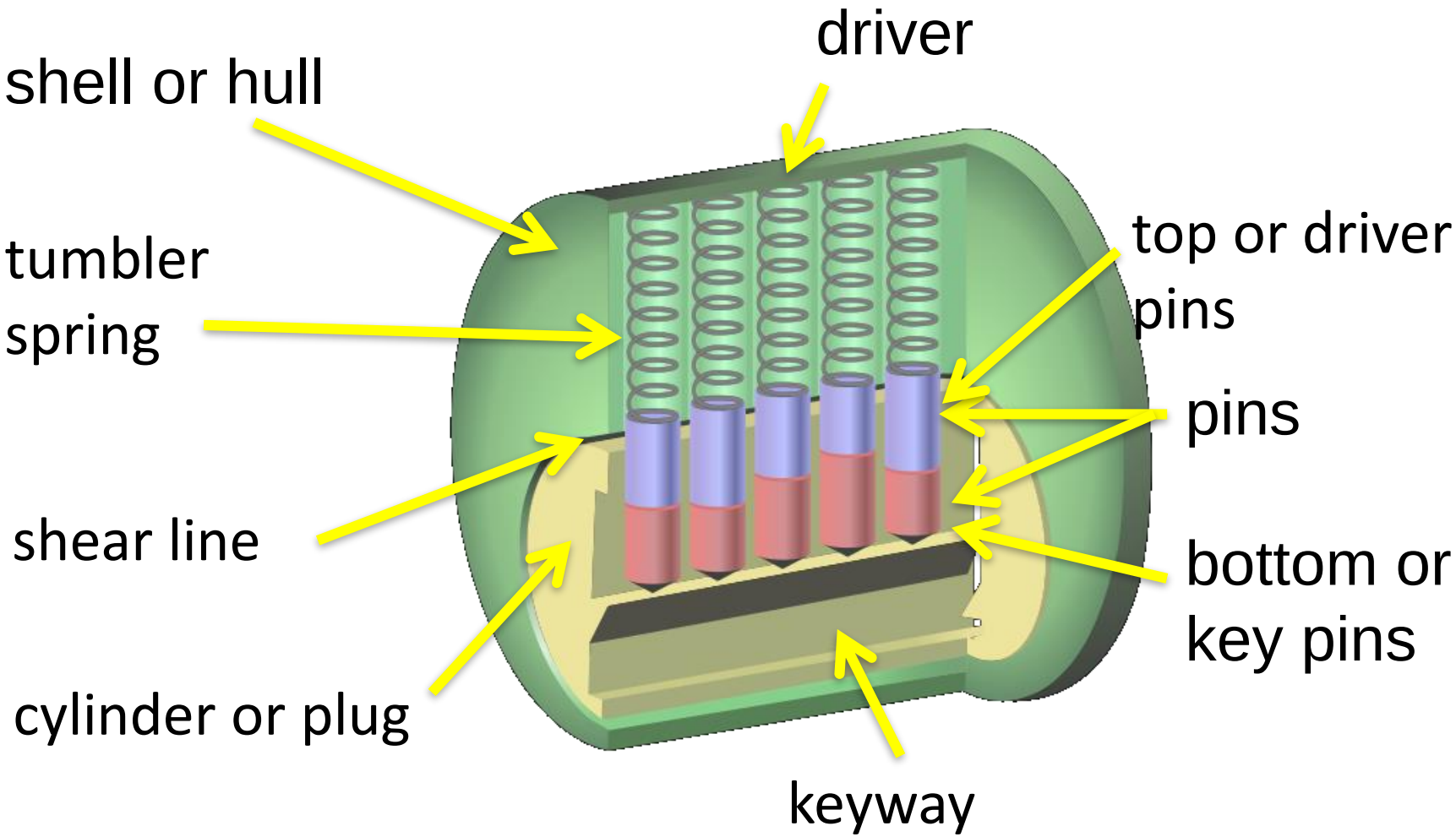
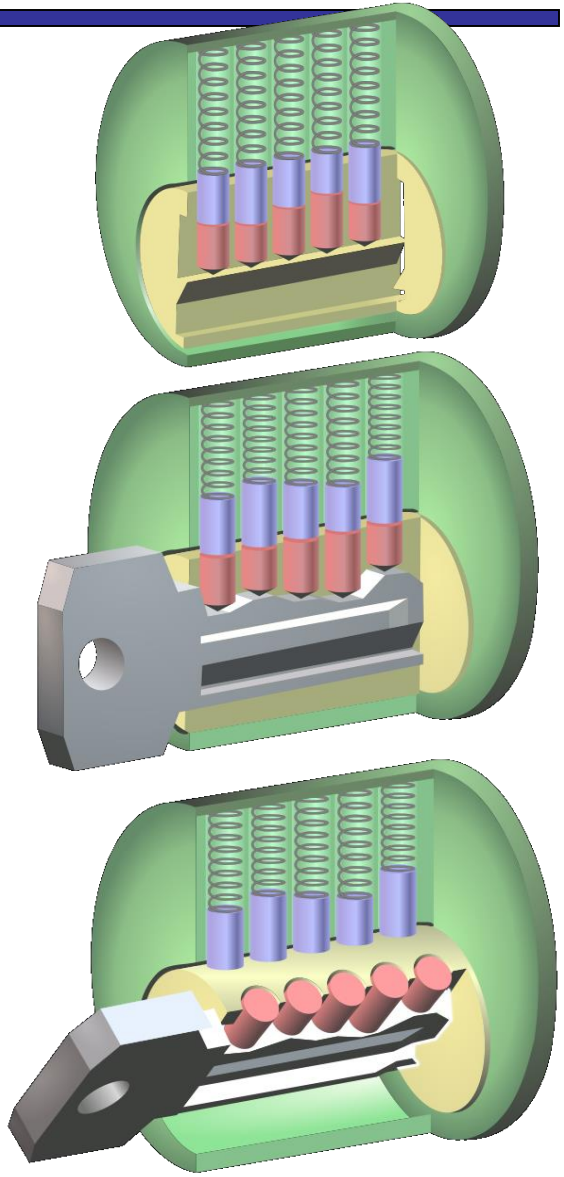


Image from http://en.wikipedia.org/wiki/File:Pin_tumbler_with_key.svg used with permission under Gnu Free Documentation License 1.2

How Does a Pin Tumbler Lock Work?

1. When a key is not present, the pin stacks are pushed down by the springs so that the driver (top) pins span the plug and the outer casing, preventing the plug from rotating.
2. When the correct key is inserted, the ridges of the key push up the pin stacks so that the cuts of the pin stacks are aligned with the shear line.
3. The alignment of the cuts with the shear line allows the plug to be rotated.



Images from http://en.wikipedia.org/wiki/File:Pin_tumbler_with_key.svg used with permission under Gnu Free Documentation License 1.2

How Does a Pin Tumbler Lock Work?

- If an inappropriate key is insered, then the pins do not align along the shear line and the lock does not turn.

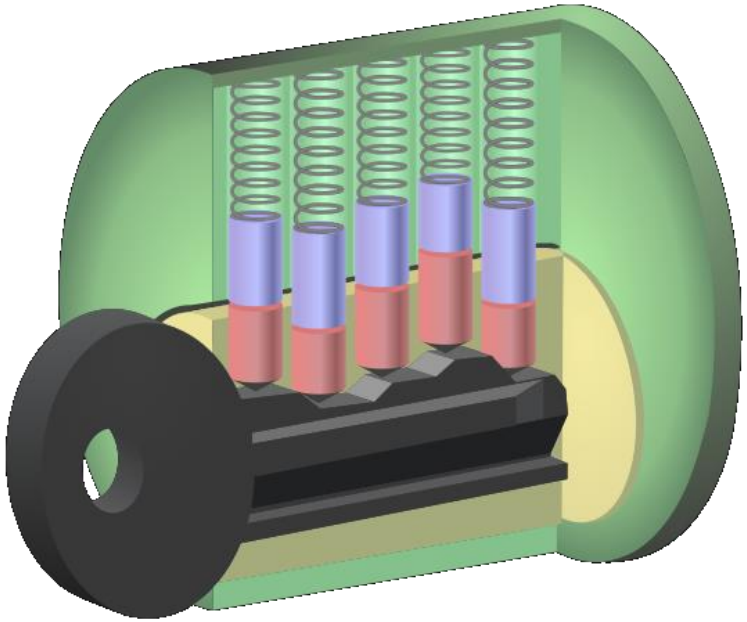


Image from http://en.wikipedia.org/wiki/File:Pin_tumbler_with_key.svg used with permission under Gnu Free Documentation License 1.2

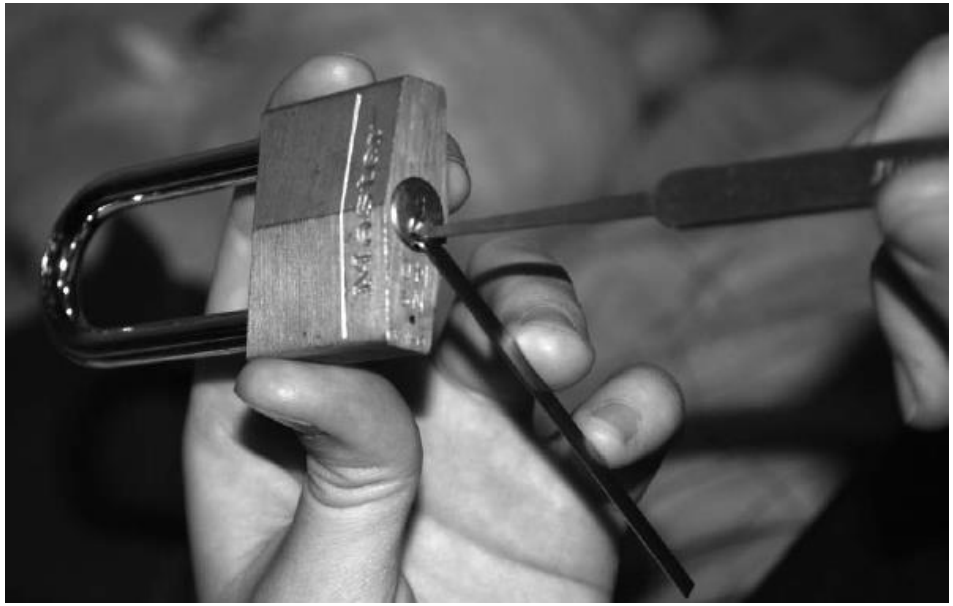


Photo by Dan Rosenberg included with permission.

LOCK PICKING

Terminology

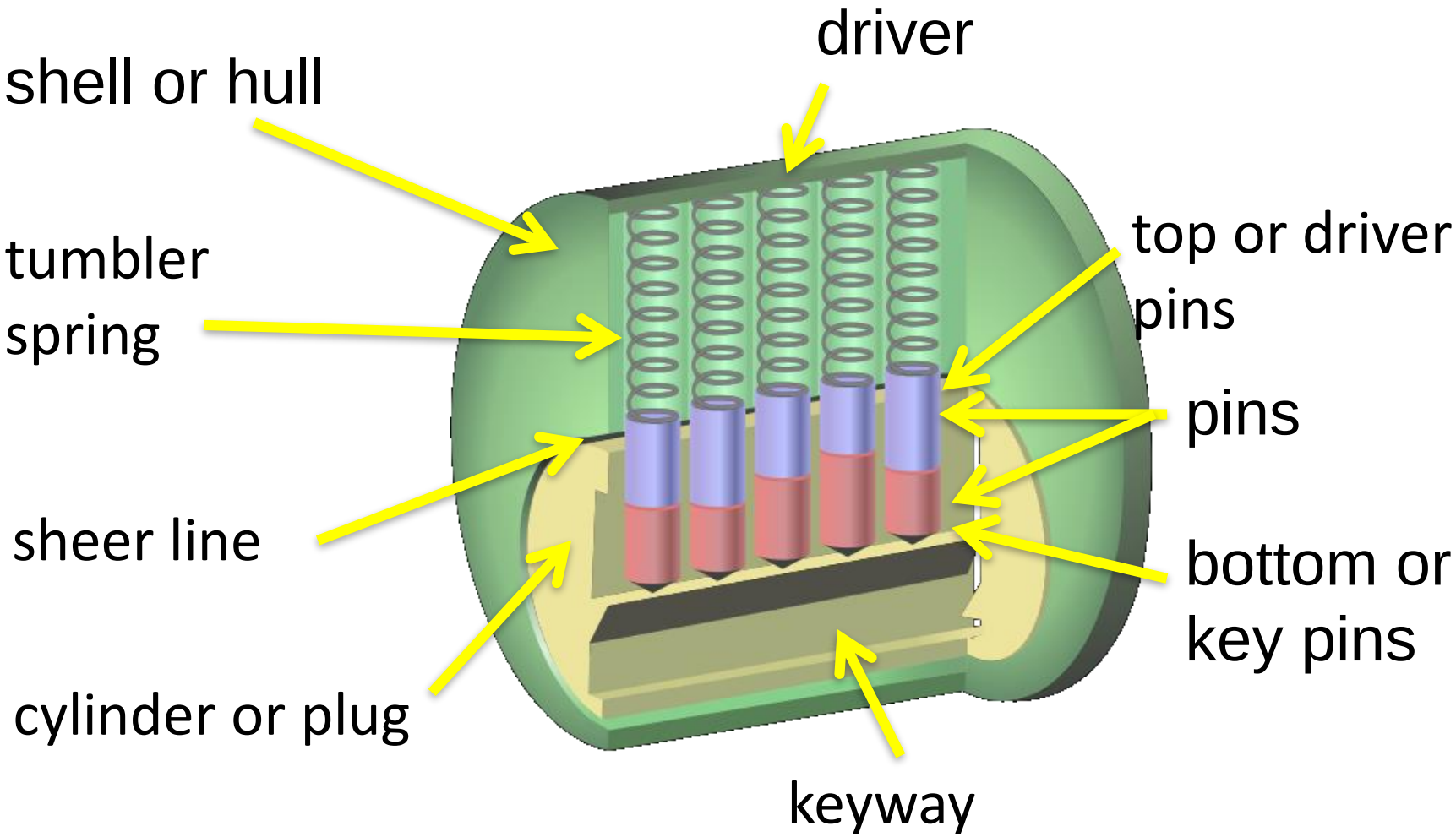


Image from http://en.wikipedia.org/wiki/File:Pin_tumbler_with_key.svg used with permission under Gnu Free Documentation License 1.2

Lockpicking Tools

- Feelers
- Scrubbers
- Tension tools

Photo by Jennie Rogers included with permission.

Feeler Picking

- Apply light tension using tension wrench
- Lift one pin at a time
  - Identify binding pin
- Lift binding pin until it reaches the shear line
- Setting the binding pin will rotate the lock slightly
- Find next pin and repeat the process

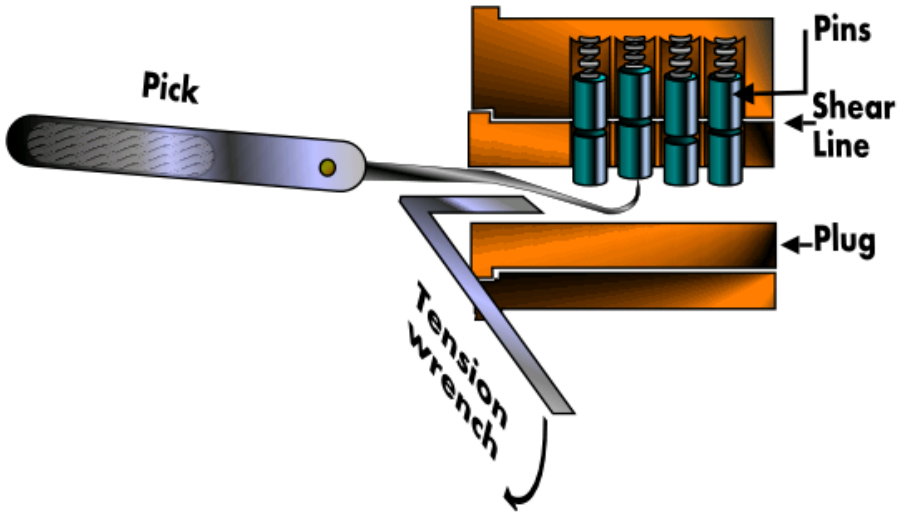


Image from http://commons.wikimedia.org/wiki/File:Pin_and_tumbler_lock_picking.PNG used with permission under Gnu Free Documentation License 1.2

Scrubbing / Raking

- Apply light tension
- Work over pins back to front in a circular motion
  - attempting to pop them into the shear line with the combination of tension
- Good for beginners
- Usually employ snake pick or half diamond
  - A pick designed to lift several pins simultaneously
  - Remaining pins can be individually picked

Photo by Jennie Rogers included with permission.

The Math of Lock Picking

- Suppose we have
  - 40 different kinds of key blanks
  - 7 pin positions
  - 8 different possible pin heights
- Then the total number of possible locks is
  - $40 \times 8^7 = 83{,}886{,}080$
- Not all these are possible, however, as it is difficult to put long teeth next to small teeth.

Authentication based on biometrics

Biometrics

- **Biometric** refers to any measure used to uniquely identify a person based on biological or physiological traits.
- Generally, biometric systems incorporate some sort of sensor or scanner to read in biometric information and then compare this information to stored templates of accepted users before granting access.

Image from http://commons.wikimedia.org/wiki/File:Fingerprint_scanner_in_Tel_Aviv.jpg
used with permission under the Creative Commons Attribution 3.0 Unported license

Requirements for Biometric Identification

- **Universality.** Almost every person should have this characteristic.
- **Distinctiveness.** Each person should have noticeable differences in the characteristic.
- **Permanence.** The characteristic should not change significantly over time.
- **Collectability.** The characteristic should have the ability to be effectively determined and quantified.

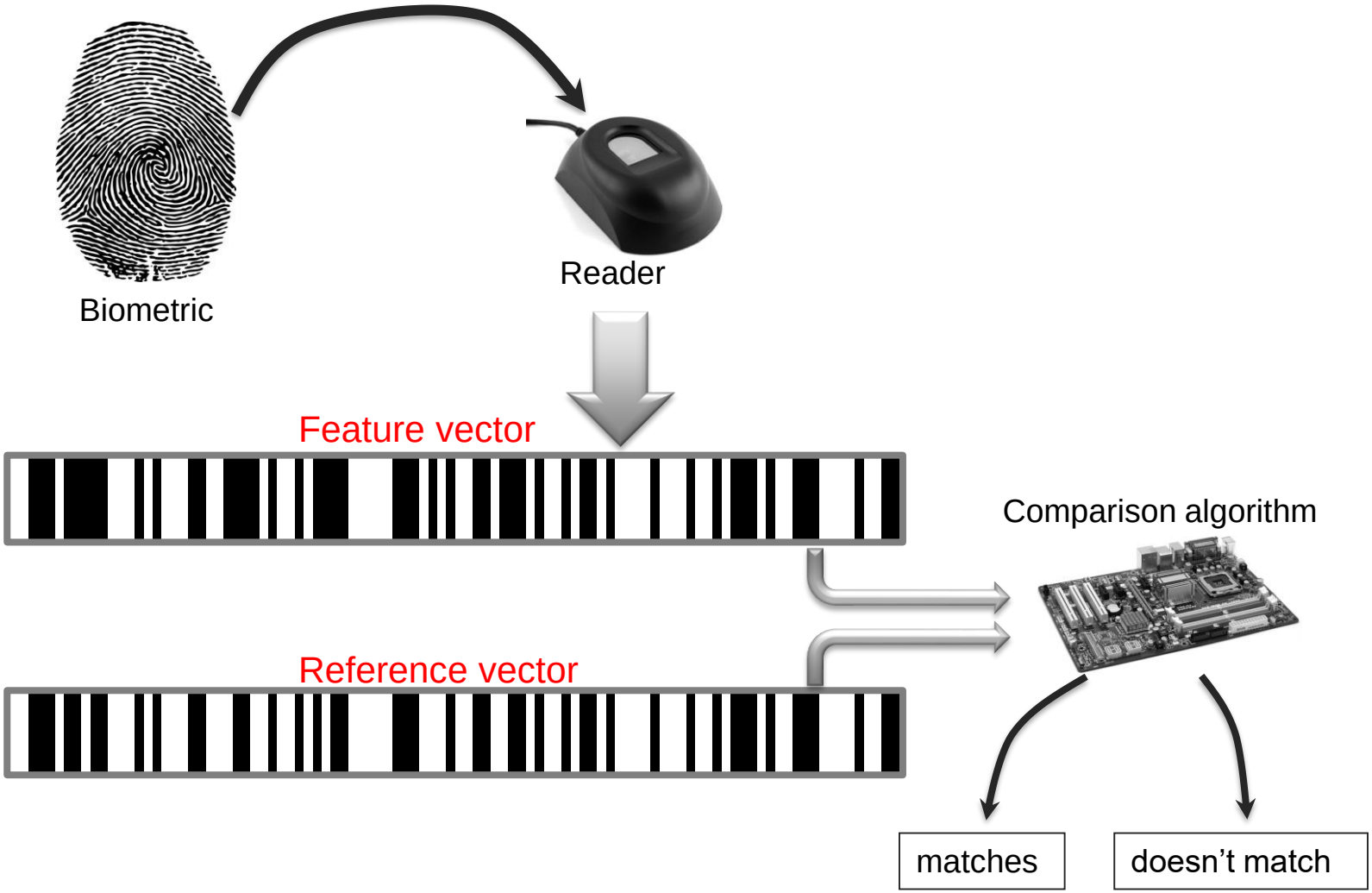
Desirable qualities for biometric features

- **Performance**: the accuracy and speed of recognition
- **Acceptability**: whether or not people are willing to accept the use of the biometric characteristic
- **Circumvention**: the degree to which the characteristic can be forged or avoided

Biometric Identification

- **Enrollment phase**: biometric is captured and stored (the reference vector, stored as a template, from which the reference vector is derived)
- **Authentication phase**: a biometric reading is performed and converted into a feature vector, which is then compared to the stored reference vector).
- Biometric matching is approximate.

Biometric Identification



Candidates for Biometric IDs

- Fingerprints
- Retinal/iris scans
- DNA
- “Blue-ink” signature
- Voice recognition
- Face recognition
- Gait recognition
- Let us consider how each of these scores in terms of universality, distinctiveness, permanence, and collectability…

Current implementations of some of these technologies are not very effective

Fingerprints: some history

- First modern systematic use of fingerprints seems to be in India in mid 19th century: use of fingerprints to prevent rich people to pay poor people to serve in prison in their place
- Discovered independently by a medical missionary in Japan
- Mainstream use in 1900 when a former chief officer from Bengal becomes Commissioner of the Metropolitan Police in London

Fingerprints: applications today

- Government identification
- Criminal identification: IAFIS “Integrated Automated Fingerprint Identification System” is the law enforcement tool used either to identify a fingerprint’s maker or to confirm prints

IAFIS

- Became operational in July 1999
- It is the United States national fingerprint and criminal history system maintained by the FBI
- It provides automated fingerprint search capabilities, latent searching capability, electronic image storage, and electronic exchange of fingerprints and responses.
- Answer received between 2 hours to 24 hours (before the integration/digital it took days sometime months)
- Largest biometric database in the world, containing the fingerprints and corresponding criminal history information for more than 47 million subjects.

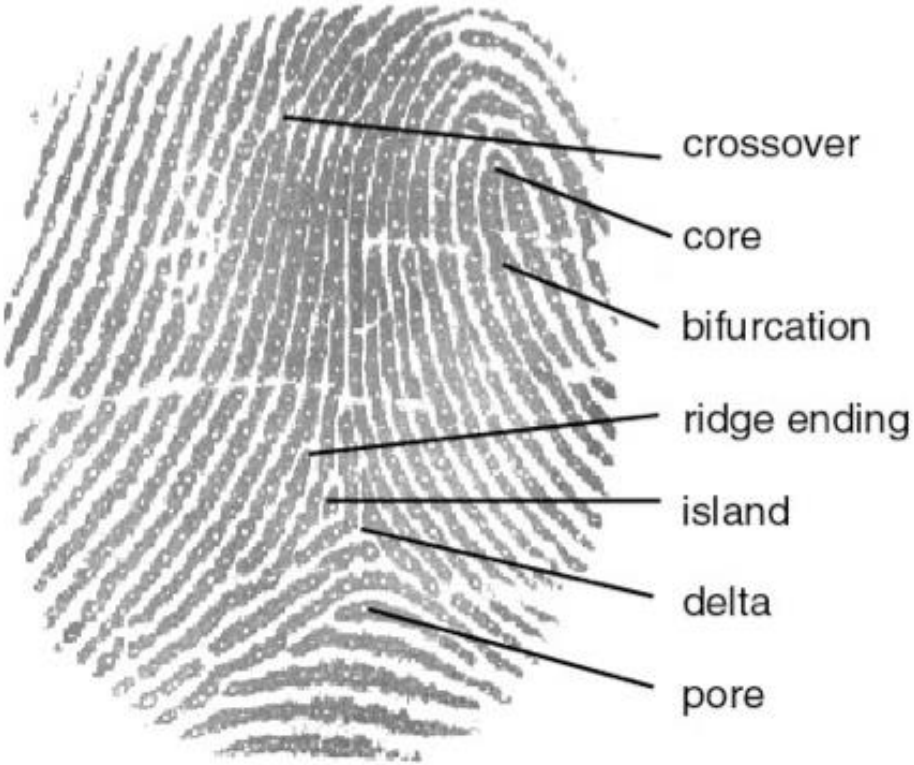
NGI

- Next Generation Identification (NGI) was announced by the FBI in 2014
- Incremental replacement of the Integrated Automated Fingerprint Identification System (IAFIS)
- Provides new functionality and improves existing capabilities
- Will be a more modular system (allowing easy expandability)
- Will also have more advanced lookup capabilities, incorporating palm print, iris, and facial identification.

- https://www.fbi.gov/about-us/cjis/fingerprints_biometrics/ngi
- http://www.networkworld.com/article/2687913/security/164703-The-FBI-s-big-bad-identification-system.html

Fingerprint Identification

- Fingerprint is made of a series of ridges and furrows
- Fingerprint uniqueness: determined by the pattern of ridges and furrows as well as the minutiae points
- Minutiae points are local ridge characteristics that occur at either a ridge bifurcation or a ridge ending



Fingerprint Identification Accuracy

- Error rate in forensic applications is very low, it depends on the quality and size of of the image taken at the crime
- Fingerprints require a number of match points, different from country to country. UK requires 16 points

Privacy and Security Concerns for Biometric Data

- Compromise of biometric data is dangerous
  - Biometric data does not change over time and it cannot be revoked
- Biometric data should be protected, both in storage and in transit
  - Use the hash of the biometric vector
  - However, such protection is not compatible with approximate matching! (e.g., when comparing a hash of the reference vector with a hash of the feature vector, the smallest change in the feature vector will result in a different hash value)
  - Approximate MACs (AMACs) have been proposed
    - Given the AMACs of two messages, it is possible to determine if the two messages are similar (within a certain threshold δ)
    - Given the AMAC of a message, it is computationally infeasible to find any message within distance δ from the message.

Direct attacks against computers

Authentication based on paper features

- In 2009, researchers developed a scheme to generate a fingerprint of blank paper using commodity scanners
  - Fingerprint is based on the paper texture
  - The document is scanned several times at different orientations
- The fingerprint can later be used to identify the same piece of paper
  - Even if the paper was scribbled on, printed on with ink, or was soaked in water and then dried
- Applications:
  - Currency counterfeit identification
  - Ticket forgery at concerts and sporting events
  - Artwork forgery (rely on features of the *canvas* upon which the work is painted – down to the detailed arrangement of the weave)

Authentication based on paper features

- But, there are also undesirable attacks, because the traditional implicit assumption that pieces of paper cannot be traced does not hold anymore
  - Unopened sheaves of blank printer paper could be fingerprinted at the factory
  - Privacy is broken for anonymous paper-based voting or any anonymous survey or reporting system

Clarkson, Weyrich, Finkelstein, Heninger, Halderman, and Felten, *"Fingerprinting Blank Paper Using Commodity Scanners"*, published in IEEE Symposium on Security and Privacy, 2009

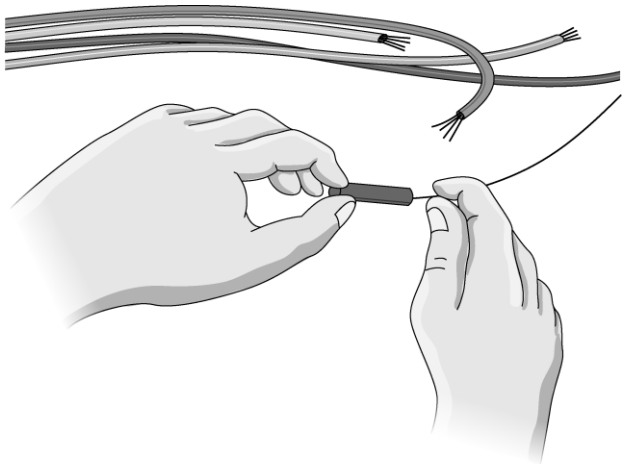
Direct attacks against computers

- Eavesdropping
- TEMPEST
- Live CDs
- Computer Forensics

Eavesdropping

- **Eavesdropping** is the process of secretly listening in on another person's conversation.
- Protection of sensitive information must go beyond computer security and extend to the **environment** in which this information is entered and read.
- Simple eavesdropping techniques include
  - Using social engineering to allow the attacker to read information over the victim's shoulder
  - Installing small cameras to capture the information as it is being read
  - Using binoculars to view a victim's monitor through an open window.
- These direct observation techniques are commonly referred to as **shoulder surfing.**

Wiretapping



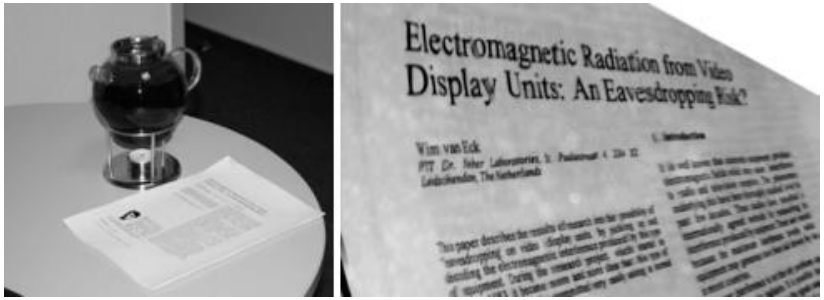
- Many communication networks employ the use of inexpensive coaxial copper where information is transmitted via electrical impulses that travel through the cables.
- Relatively inexpensive means exist measure these impulses and can reconstruct the data being transferred through a tapped cable, allowing an attacker to eavesdrop on network traffic.
- These **wiretapping attacks** are passive, in that there is no alteration of the signal being transferred, making them extremely difficult to detect.

Wiretapping

- Traditional taps
  - Similar to a signal splitter, but the outputs are not equal in signal strength. The "through" output of a tap may only reduce the signal level by a very small amount, while the "tap" output is a small fraction of the signal level.
  - Requires to cut the cable and connect the two ends to a sniffing device
  - Intrusion detection tools can detect this because the wire is disconnected for a period of time
- Passive Splice Tap
  - Tap without disconnecting the link (stealthy)
  - http://www.janitha.com/archives/146

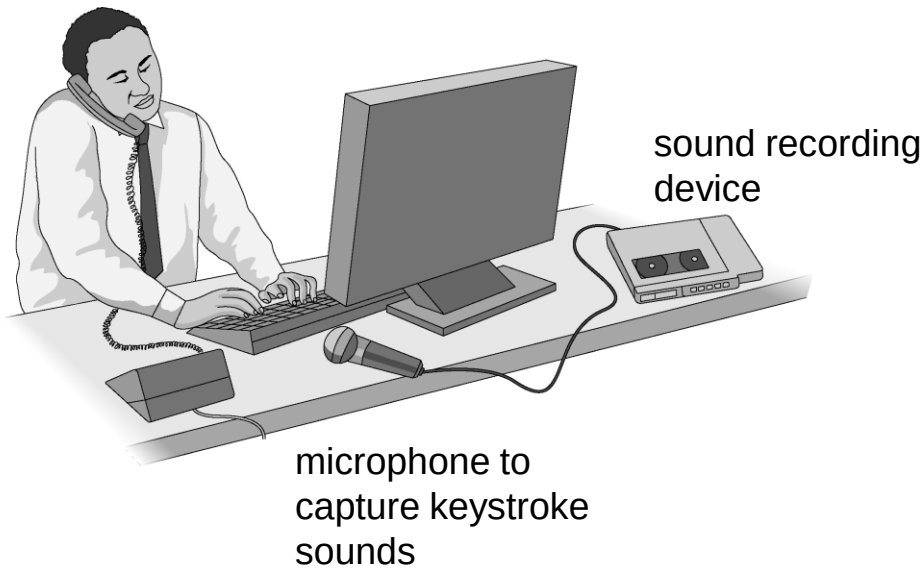
Signal Emanations

- Computer screens emit **radio frequencies** that can be used to detect what is being displayed.
- **Visible light** reflections can also be used to reconstruct a display from its reflection on a wall, coffee mug, teapot, spoon, plastic bottle, eyeglasses, or even a person's eye!



Acoustic Emissions

- Dmitri Asonov and Rakesh Agrawal published a paper in 2004 detailing how an attacker could use an audio recording of a user typing on a keyboard to reconstruct what was typed.
  - Each keystroke has minute differences in the sound it produces, and certain keys are known to be pressed more often than others.
  - After training an advanced neural network to recognize individual keys, their software recognized an average 79% of all keystrokes.



D. Asonov and R. Agrawal, *"Keyboard acoustic emanations"*, in IEEE Symposium on Security and Privacy, 2004.

Other Acoustic Side Channels

- Subtle acoustic noise emanating from LCD computer screens can be used to detect content displayed on the screen
  - Microphones built into webcams or screens

D. Genkin, M. Pattani, R.Schuster, and E. Tromer, *"Synesthesia: Detecting Screen Content via Remote Acoustic Side Channels"*, in IEEE Symposium on Security and Privacy, 2019.

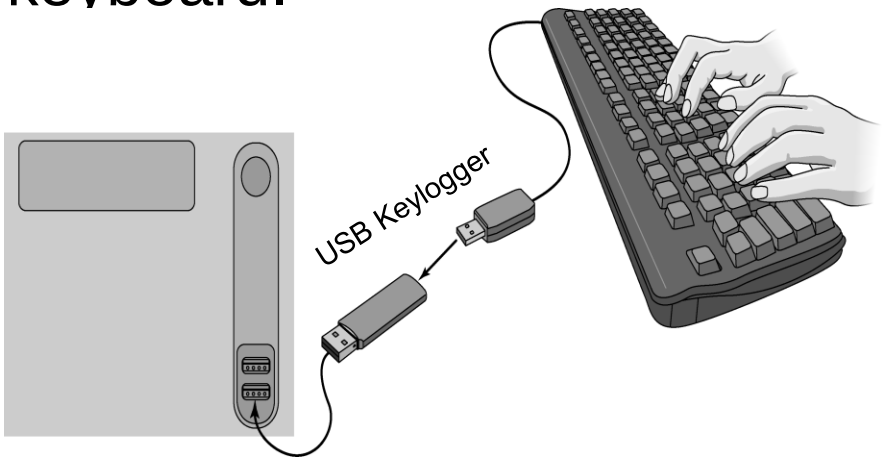
More acoustic side channels

- Eavesdropping HDDs!
- Mechanical components in magnetic hard disk drives behave as microphones with sufficient precision to extract and parse human speech
  - Attackers control the HDD firmware, thus able to record the HDD's Position Error Signal
- Even if we disable all known sensors, non-sensors can be synthesized into intrusive sensors (HDD can be used as a microphone)
  - Shazam service to identify songs recorded through the hard disk drive

A. Kwong, W. Xu and K. Fu, *"Hard Drive of Hearing: Disks that Eavesdrop with a Synthesized Microphone"*, in IEEE Symposium on Security and Privacy, 2019

Hardware Keyloggers

- A keylogger is any means of recording a victim's keystrokes, typically used to eavesdrop passwords or other sensitive information.
- Hardware keyloggers are typically small connectors that are installed between a keyboard and a computer.
- For example, a USB keylogger is a device containing male and female USB connectors, which allow it to be placed between a USB port on a computer and a USB cable coming from a keyboard.



Hardware Keyloggers

- Keylogger disguised as USB wall charger can intercept all keystrokes from a wireless keyboard in the vicinity:

http://www.networkworld.com/article/2868663/microsoft-subnet/hacker-builds-wireless-microsoft-keyboard-keylogger-disguised-as-usb-wall-charger.html

- Some comments on defenses:

http://www.zdnet.com/article/a-10-usb-charger-with-built-in-wireless-keylogger-is-a-security-nightmare/

TEMPEST

- **TEMPEST** is a U.S. government code word for a set of standards for limiting information-carrying electromagnetic emanations from computing equipment.
- TEMPEST establishes three zones or levels of protection:
  1. An attacker has almost direct contact with the equipment, such as in an adjacent room or within a meter of the device in the same room.
  2. An attacker can get no closer than 20 meters to the equipment or is blocked by a building to have an equivalent amount of attenuation.
  3. An attacker can get no closer than 100 meters to the equipment or is blocked by a building to have an equivalent amount of attenuation.

Emanation Blockage

- To block visible light emanations, we can enclose sensitive equipment in a windowless room.
- To block acoustic emanations, we can enclose sensitive equipment in a room lined with sound-dampening materials.
- To block electromagnetic emanations in the electrical cords and cables, we can make sure every such cord and cable is well grounded and insulated.

Faraday Cages

- To block electromagnetic emanations in the air, we can surround sensitive equipment with metallic conductive shielding or a mesh of such material, where the holes in the mesh are smaller than the wavelengths of the electromagnetic radiation we wish to block.
- Such an enclosure is known as a **Faraday cage.**

Live CDs

- A live CD contains an operating system that can be booted from an external device (CD, DVD, USB drive)
  - Attacker then mounts the hard disk and reads/writes data, bypassing the OS's authentication mechanisms
- Defense: install a BIOS password
  - The attacker cannot boot the computer without the password
- Attacker can still physically remove the hard disk and mount it in another machine
  - Can be prevented with hard disk encryption

Computer Forensics

- **Computer forensics** is the practice of obtaining information contained on an electronic medium, such as computer systems, hard drives, and optical disks, usually for gathering evidence to be used in legal proceedings.

- Unfortunately, many of the advanced techniques used by forensic investigators for legal proceedings can also be employed by attackers to uncover sensitive information.

Computer Forensics

- Forensic analysis typically involves the physical inspection of the components of a computer, sometimes at the microscopic level, but it can also involve electronic inspection of a computer's parts as well.

Computer Forensics

- Recover deleted data from a hard drive
  - When a file is deleted, filesystems usually remove only the file's metadata (name, size, location on disk), without overwriting the contents of the file data on the disk. Forensic tools can be used to recover "deleted" data.
  - To safely delete classified information, U.S. Government standards mandate data to be overwritten with multiple passes of random data or be physically destroyed.
    - Secure Erase tool (by researchers from UCSD)

Computer Forensics

Mail Online

Home | U.K. Home | News | Sport | U.S. Showbiz | Femail | Health | Science | Money | Rig

News Home | Arts | Headlines | Pictures | Most read | News Board

hotels.com AdChoices
SAVE UP TO 40% ON FALL TRAVEL
Book Now

Computer hard drive sold on eBay 'had details of top secret U.S. missile defence system'

By DAILY MAIL REPORTER

Last updated at 11:08 AM on 7th May 2009

Comments (0) | Add to My Stories | Share | Like

Highly sensitive details of a US military missile air defence system were found on a second-hand hard drive bought on eBay.

The test launch procedures were found on a hard disk for the THAAD (Terminal High Altitude Area Defence) ground to air missile defence system, used to shoot down Scud missiles in Iraq.

The disk also contained security policies, blueprints of facilities and personal information on employees including social security numbers, belonging to technology company Lockheed Martin - who designed and built the system

How your office copier is spying on you in an unbelievable way – it has a hard disk on-board that stores every page copied

by Marshall Brain | May 8, 2010

Like | Send | 518 people like this. Be the first of your friends. | Tweet 30

This is an amazing, unbelievable – some would say shocking – revelation. Office copying machines contain hard disks that store an image of every page copied by the copier. The material is not encrypted, so if a burglar, corporate spy or identity theft ring gets hold of the copier's hard disk, they can access a treasure trove of personal information about employees and clients. They can also access company financial information, trade secrets, pay checks… anything put on the copier is stored.

Computer Forensics – cold boot attacks

- Team of Princeton researchers presented a technique in 2008 to access memory contents after the computer has been shutdown
  - Freeze the DRAM memory modules of a running computer by using a refrigerant (e.g., the liquid contained in a canned-air duster)
  - Power off the computer
  - Boot computer from a live CD equipped with a special program that reconstructs the memory image and extracts the disk encryption key.

Figure 5: Before powering off the computer, we spray an upside-down canister of multipurpose duster directly onto the memory chips, cooling them to −50°C. At this temperature, the data will persist for several minutes after power loss with minimal error, even if we remove the DIMM from the computer.

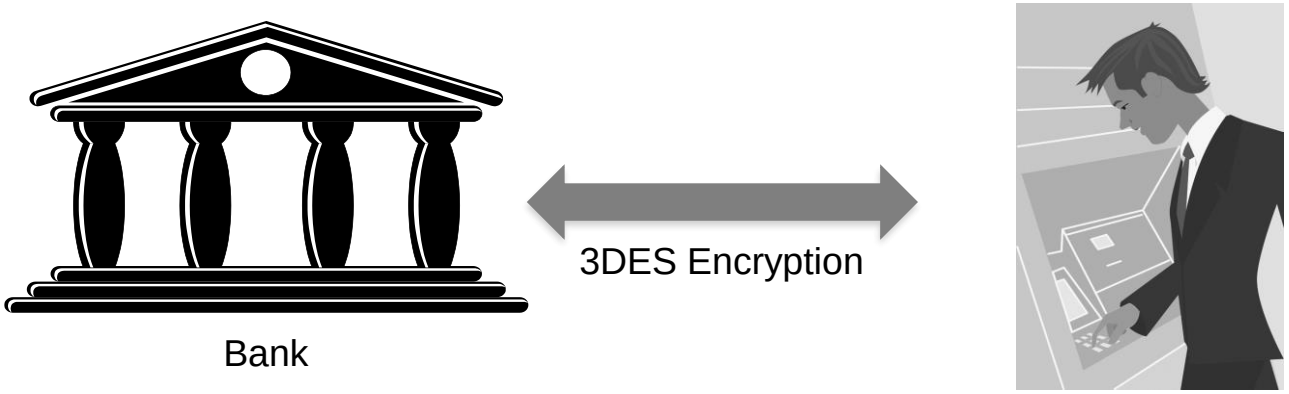
ATMs

- An **automatic teller machine (ATM)** is any device that allows customers of financial institutions to complete withdrawal and deposit transactions without human assistance.
- Typically, customers insert a magnetic stripe credit or debit card, enter a PIN, and then deposit or withdraw cash from their account.
- The ATM has an internal cryptographic processor that encrypts the entered PIN and compares it to an encrypted PIN stored in a remote database or stored on the card (only for older systems that are not connected to a network).

ATM

ATMs

- To ensure the confidentiality of customer transactions, each ATM has a cryptographic processor that encrypts all incoming and outgoing information, starting the moment a customer enters their PIN.
- The current industry standard for ATM transactions is the **Triple DES (3DES) cryptosystem,** a legacy symmetric cryptosystem with up to 112 bits of security.
- The 3DES secret keys installed on an ATM are either loaded on-site by technicians or downloaded remotely from the ATM vendor.



Attacks on ATMs

- **Lebanese loop:** A perpetrator inserts this sleeve into the card slot of an ATM. When a customer attempts to make a transaction and inserts their credit card, it sits in the sleeve, out of sight from the customer, who thinks that the machine has malfunctioned. After the customer leaves, the perpetrator can then remove the sleeve with the victim's card.

Attacks on ATMs

- **Skimmer:** a device that reads and stores magnetic stripe information when a card is swiped. An attacker can install a skimmer over the card slot of an ATM and store customers' credit information without their knowledge. Later, this information can be retrieved and used to make duplicates of the original cards.

Attacks on ATMs

Attacks on ATMs

- Criminals Hit the ATM Jackpot

http://www.symantec.com/connect/blogs/criminals-hit-atm-jackpot

- Backdoor.Ploutus Reloaded – Ploutus Leaves Mexico

http://www.symantec.com/connect/blogs/backdoorploutus-reloaded-ploutus-leaves-mexico

- ATM malware may spread from Mexico to English-speaking world

http://www.networkworld.com/news/2013/102813-atm-malware-may-spread-from-275276.html

Other attacks using rogue hardware

- Rogue hardware used in attempted cyberheist at Santander bank branch

http://www.networkworld.com/news/2013/091313-rogue-hardware-used-in-attempted-273848.html

More attacks….

- Hacking into a sniper rifle:

http://www.wired.com/2015/07/hackers-can-disable-sniper-rifleor-change-target/

- Hacking into cars:

http://www.darkreading.com/attacks-breaches/state-trooper-vehicles-hacked-/d/d-id/1322415

Social Engineering

- Social Engineering refers to the use of human insiders to circumvent computer security solutions.

- **Pretexting**: creating a story that convinces an administrator or operator into revealing secret information.
- **Baiting:** offering a kind of “gift” to get a user or agent to perform an insecure action.
- **Quid pro quo:** offering an action or service and then expecting something in return.

Social Engineering

- Con artists don't try to make you trust them, but they try to convince you that they trust you.
  - See “pidgeon drop” trick
  - http://www.youtube.com/watch?v=Ur3nMiP-XV0
- What do scammers put on the USB sticks that are dropped in the parking lot?

  A label with:
  - porn (e.g., wife pics)
  - secret/confidential
  - employee bonuses
  - It is not possible to achieve 100% immunization against social engineering.

Social Engineering (additional reading)

https://nordvpn.com/blog/social-engineering/

Read more about:

- Phishing
- Spear phishing
- Vishing
- Pretexting
- Catfishing
- Baiting
- Quid pro quo
- Contact spamming

What to read?

- For “Authentication based on physical tokens”, Chapters 2.1, 2.3 from the Textbook
- For “Locks and safes”, Chapter 2.2 from the Textbook
- For “Authentication based on biometrics”, Chapter 2.3.5 from the Textbook
- For “Direct attacks against computers”, Chapters 2.4, 2.5 from the Textbook